SEGURANÇA E COMPLIANCE

SUMÁRIO

COMPUTAÇÃO EM NUVEM 4

COMPUTAÇÃO EM NUVEM, UM PARADIGMA EM ASCENSÃO 5

MODELOS DE SERVIÇOS NA COMPUTAÇÃO EM NUVEM 5

SEGURANÇA EM AMBIENTES NA NUVEM..... 7

GERENCIAMENTO DA SEGURANÇA DA INFORMAÇÃO NA NUVEM 8

PROCESSO DE GERENCIAMENTO DE RISCO NA NUVEM 10

MODELO PARA GESTÃO DE RISCO NA NUVEM 13

GESTÃO DE RISCO 14

REQUISITOS PARA A GESTÃO DE RISCO NA NUVEM 16

COMPLIANCE E A NECESSIDADE DE SUA ADOÇÃO 18

COMPLIANCE NA PREVENÇÃO 19

CONTROLES PARA A IMPLANTAÇÃO DA LGPD.....24

PG00 - PROGRAMA DE GESTÃO DE CIBERSEGURANÇA E SEGURANÇA DA INFORMAÇÃO.....26

PG06 - PROGRAMA DE INFORMAÇÕES PROTEGIDAS.....27

PG03 - PROGRAMA DE CONTINUIDADE DE NEGÓCIOS.....29

GC3.1. BACKUP.....29

PG08 - PROGRAMA DE ATITUDES SEGURAS.....30

GC8.2. TREINAMENTO.....30

REFERÊNCIAS..... 3233

NOSSA HISTÓRIA

A nossa história inicia com a realização do sonho de um grupo de empresários, em atender à crescente demanda de alunos para cursos de Graduação e Pós-Graduação. Com isso foi criado a nossa instituição, como entidade oferecendo serviços educacionais em nível superior.

A instituição tem por objetivo formar diplomados nas diferentes áreas de conhecimento, aptos para a inserção em setores profissionais e para a participação no desenvolvimento da sociedade brasileira, e colaborar na sua formação contínua. Além de promover a divulgação de conhecimentos culturais, científicos e técnicos que constituem patrimônio da humanidade e comunicar o saber através do ensino, de publicação ou outras normas de comunicação.

A nossa missão é oferecer qualidade em conhecimento e cultura de forma confiável e eficiente para que o aluno tenha oportunidade de construir uma base profissional e ética. Dessa forma, conquistando o espaço de uma das instituições modelo no país na oferta de cursos, primando sempre pela inovação tecnológica, excelência no atendimento e valor do serviço oferecido.

(Fonte: Google)

1. COMPUTAÇÃO EM NUVEM

A Computação em Nuvem (*Cloud Computing*) é fruto da evolução e da reunião dos fundamentos técnicos de áreas como virtualização de servidores, *Grid Computing* (Computação em Grade), Software orientado a serviços, gestão de grandes instalações (Data Centers), dentre outras. Trata-se de um modelo eficiente para utilizar softwares, acessar, armazenar e processar dados por meio de diferentes dispositivos e tecnologias web. Na prática, a Computação em Nuvem seria a transformação dos sistemas computacionais físicos de hoje em uma base virtual.

De forma mais ampla, o paradigma da Computação em Nuvem parte do princípio de que todos os recursos de infraestrutura de TI (hardware, software e gestão de dados e informação), até então tratada como um ativo da empresa usuária, passam a ser acessados e administrados por estas através da internet (Nuvem) com o uso de um simples navegador da rede mundial de computadores, utilizando-se qualquer tipo de equipamento celulares inteligentes, notebooks, netbooks, desktops, etc.

Fornecedores de tecnologia passam a prover a infraestrutura e os serviços capacitados para atender a essa demanda. Nesse cenário delineia-se uma série de

questões que ainda precisam ser respondidas, afim de que se possibilite a sua plena utilização e adoção sem receios pelas empresas.

1.1. Computação em nuvem, um paradigma em ascensão

Embora o paradigma da Computação em Nuvem esteja fundamentado na utilização de ferramentas fortemente difundidas em Tecnologia da Informação e Comunicação (TIC), (Next Generation, 2009) ele tem como principal característica a transformação dos modos tradicionais de como empresas utilizam e adquirem os recursos de TIC.

Na adoção do modelo de Computação em Nuvem os processos de negócios e procedimentos precisam levar em conta a segurança e privacidade das informações que ficarão na nuvem.

A problemática é como adotar modelos de segurança em um paradigma totalmente novo para as práticas do mercado. Os questionamentos de como lidar com a segurança das informações armazenadas na nuvem, nos leva à busca de soluções que visam padronizar a adoção dos serviços da nuvem.

A solução mais adequada está vinculada à definição de padrões de governança de TI, que permitam as organizações identificar e catalogar as informações que serão armazenadas na nuvem. A adequação das políticas de segurança da informação auxiliará a definição de diretrizes para que o consumo dos serviços da nuvem possua um nível de segurança aceitável.

2. MODELOS DE SERVIÇOS NA COMPUTAÇÃO EM NUVEM

Ambientes de computação em nuvem podem ser compostos por três diferentes modelos de serviços que definem um padrão arquitetural para soluções de computação em nuvem (Armbrust et al. 2009). Riscos e benefícios globais serão

diferentemente tratados, dependendo do modelo de serviço e tipo de implantação que atenderá as necessidades da empresa contratante. É importante notar que, ao se considerar os diferentes tipos de serviços e modelos de implantação, as empresas devem considerar os riscos que os acompanham.

- **Software como Serviço *(Software as a Service - SaaS):*** Nesse modelo de serviço o software é executado em um servidor, não sendo necessário instalar o sistema no computador do cliente, basta acessá-lo por meio da internet. O modelo de serviço de SaaS ainda tem uma série de desafios a serem vencidos, dentre os quais podemos destacar os problemas regulatórios, a integração com os recursos internos da organização, a disponibilidade e mais especificamente a segurança das informações.
- **Infraestrutura como Serviço *(Infrastructure as a Service – IaaS)*:** Esse modelo de serviço refere-se ao fornecimento de infraestrutura computacional (geralmente em ambientes virtualizados) como um serviço. O serviço IaaS possui algumas características básicas como, fornece uma interface única para administração da infraestrutura; provisionamento dinâmico de serviços; Alta-disponibilidade; e Balanceamento de carga de maquinas virtuais;
- **Plataforma como Serviço *(Platform as a Service - PaaS)*:** Esse modelo de serviço caracteriza-se pela entrega de uma plataforma para desenvolvimento, teste e disponibilização de aplicativos web com a finalidade de facilitar a implantação de aplicações sem os custos e complexidade de gerenciamento do hardware. Um fator inibidor de adoção é que aplicações desenvolvidas em uma PaaS normalmente fica presa ao fornecedor. É preciso que futuros clientes estejam atentos a esse detalhe.

3. SEGURANÇA EM AMBIENTES NA NUVEM

(Fonte: Google)

Em um ambiente computacional tradicional, é comum observarmos que os requisitos de segurança são ignorados em detrimento dos requisitos funcionais dos sistemas. Tal fato ocasiona o desenvolvimento de sistemas e ambientes extremamente vulneráveis aos ataques externos.

Quando o assunto se relaciona aos riscos associados à Computação em Nuvem, modelo de entrega de soluções e sistemas hospedados em fornecedores terceiros - a conversa geralmente envereda por questões relacionadas à privacidade e segurança das informações residentes na nuvem.

Apesar dessas preocupações, o debate sobre os riscos na nuvem muitas vezes ignora a importância de criar planos de contingência e Acordo de Níveis de Serviço (ANS) (em inglês SLA – *Service Level Agreement*), voltados a garantir confiabilidade e a certeza de que os negócios não sofrerão grandes baques no caso de um incidente.

Os riscos referentes à segurança e privacidade das informações na Nuvem bem como a portabilidade dos dados delineia-se como sendo de alta criticidade. Além disso, quando as informações críticas das empresas estão nas mãos de outras pessoas também pode refletir em menos garantia do cumprimento das leis.

Na computação tradicional, ambientes *in-house*, os usuários têm total controle sobre seus dados, processos e seu computador (Kandukuri et. al., 2009). Em contrapartida, na Computação em Nuvem todos os serviços e manutenção dos dados são fornecidos por um provedor de nuvem.

Neste contexto o cliente (usuário) desconhece quais processos estão em execução ou onde os dados estão armazenados, essa abstração de atividades se deve justamente ao dinamismo inerente da nuvem. Sendo assim o cliente não tem controle sobre todas as movimentações de seus dados na nuvem. Então como exigir garantias de que as informações residentes na nuvem estão realmente seguras?

Muitos dos riscos frequentemente associados com a Computação em Nuvem não são novos, e podem ser encontrados nas empresas de hoje (ISACA, 2009). A questão é como adequar padrões existentes na computação tradicional à Computação em Nuvem? O fato é que por não termos um histórico com o serviço de Computação em Nuvem para se criar padrões firmes ou trabalhar com fornecedores de nuvem diferenciados, torna-se difícil generalizar a partir dessa experiência.

Segundo Paul Simmonds, do Jericho Fórum "Ainda é preciso trabalhar muito antes que a indústria entenda de onde vêm os furos de segurança em computação em nuvem". Esses questionamentos impulsionam às equipes de TIC a quebrarem antigos paradigmas e a buscar cada vez mais adoção das melhores práticas em segurança, caso suas organizações pretendam desfrutar dos benefícios da Computação em Nuvem.

3.1. Gerenciamento da segurança da informação na nuvem

Ao analisar o cenário atual para o gerenciamento de segurança da informação em ambientes de Computação em Nuvem, muitas literaturas apontam a necessidade e a importância de se adotar um modelo de Governança da Segurança da Informação com a finalidade de mitigar os riscos inerentes dos modelos de prestação de serviços na Nuvem.

Considerando a multiplicidade de serviços prestados pelos provedores de Computação em Nuvem, tais como, e-mails, desenvolvimento de aplicativos personalizados, armazenamento de dados e gestão de infraestrutura, podemos considerar que esses são concentrações maciças de recursos e dados. A percepção de que a nuvem é um aglomerado de informações pode caracterizá-la como sendo um alvo propício a ataques por potenciais invasores. Ameaças como esta podem afetar diretamente os pilares da segurança da informação: disponibilidade, confidencialidade e integridade, e consequentemente comprometer toda a nuvem.

A garantia do cumprimento desses princípios relaciona-se diretamente com o modelo de implantação contratado pela empresa, por exemplo, o modelo de Nuvem Privada, que permite a restrição de acessos uma vez que se encontra atrás do Firewall da empresa, mantendo, dessa forma, controle do nível de serviço e aderência às regras de segurança da empresa (Turion, 2009).

Na Tabela 1, resume-se uma análise do modelo de implantação de Nuvem Publica de acordo com princípios de segurança da informação, considerando questões que devem ser abordadas antes da adoção do modelo. Dessa forma uma metodologia de gestão de riscos, auxiliará na implantação de controles e adoção de medidas para a continuidade de negócios, e ainda resguardar os princípios da segurança da informação.

- **Tabela 1 – Princípios da Segurança da Informação em um modelo de Nuvem Publica.**

Princípios da Segurança	Cenário do Risco	Questões
Integridade	Invasões por hackers aos ambientes da nuvem. Violação de leis de proteção de dados.	Quais são as garantias sobre a preservação da integridade dos dados?
Confidencialidade	Aplicações de diversos usuários coabitam nos mesmos sistemas de armazenamento.	Como é realizada a segregação de dados? Como é protegida a propriedade intelectual e segredos comerciais?
Disponibilidade	Recuperação de dados gerenciados por terceiros.	Como é garantida a arquitetura de disponibilidade? A recuperação de informações críticas, está sujeita a atrasos?
Autenticidade	Verificação da autenticidade das entidades comunicantes.	Que recursos são utilizados na autenticação e controle de acesso dos usuários?
Não-repúdio	Auditabilidade das ações executadas por usuários no sistema.	Os usuários do modelo são capazes de negarem suas ações?

4. PROCESSO DE GERENCIAMENTO DE RISCO NA NUVEM

No cenário corporativo é comum observar que as questões de segurança da informação não são tratadas em um nível de gestão da organização, tendo como consequência a falta de recursos para minimizar os riscos existentes ao nível exigido pela estratégia organizacional e definido pela análise de risco. Esse comportamento

corporativo agrava-se quando os riscos em questão estão relacionados à contratação dos serviços da Nuvem

O processo de Gestão de Risco na nuvem exigirá modificações significativas na forma como hoje as organizações trabalham para mitigar os riscos, principalmente os relacionados à segurança da informação. Toda a legislação vigente, específicas para gestão de riscos de segurança da informação, foi criada e desenvolvida antes do surgimento dos modelos de serviços proporcionados pela Computação em Nuvem. Segundo Miller, et. al. (2009), os principais objetivos do processo de Gestão de Risco na nuvem, incluem:

- O planejamento para proteção da informação baseados em ativos e em Planos de Mitigação de Riscos;
- Reforçar a capacidade da organização para selecionar e aplicar a proteção baseada no risco específico e nas ameaças que afetam um determinado ativo;
- Assegurar que uma metodologia de gestão de risco de segurança da informação está sendo utilizada em toda organização.

A adoção de um modelo de serviço de nuvem mal dimensionado pode representar sérias ameaças de segurança da informação para as empresas. Principalmente para aquelas que buscam economizar em licenciamento de software e serviços de infraestrutura. A inexistência da adoção de um modelo de boas práticas em segurança da informação poderá expor as empresas a um desastre de continuidade de negócios.

Um modelo de Gestão de Risco bem delineado se torna crucial para garantir que a informação está ao mesmo tempo disponível, protegida e segura. Os processos de negócios e procedimentos precisam levar em conta a segurança, e os gerentes de segurança da informação precisam ajustar suas políticas e procedimentos de segurança para atender às necessidades do negócio. Alguns exemplos de riscos de computação em nuvem para a empresa que precisam ser gerenciados incluem:

- A escolha de um provedor de nuvem caracteriza-se como sendo um ponto extremamente crítico no processo de adoção do modelo. As empresas precisam concentrar uma atenção especial nesse ponto. Quesitos como reputação, a história e a sustentabilidade são fatores que devem ser levados em consideração. A sustentabilidade é de especial importância para garantir que os serviços estarão disponíveis e os dados poderão ser rastreados.
- O fornecedor de nuvem muitas vezes assume a responsabilidade pela manipulação da informação, aspecto que deve ser tratado como crítico para o negócio. Qualquer dificuldade ou falha para se cumprir os SLAs acordados impactará não somente na confidencialidade, mas também na disponibilidade, afetando severamente as operações do negócio.
- A natureza dinâmica da computação em nuvem pode resultar em confusão a respeito de onde a informação realmente reside. Para negócios onde a recuperação da informação é crítica, isso poderá gerar atrasos.
- O acesso de terceiros às informações sensíveis cria um risco de comprometimento das informações confidenciais. Na nuvem, isto pode representar uma ameaça significativa para a proteção da propriedade intelectual e de segredos comerciais.
- Os aspectos legais relacionados à localização física dos Data Centers, quando esses estão localizados em países com um sistema legal instável, poderá levar à violação de leis de proteção de dados, afetando diretamente à empresa. Dessa forma a conformidade com os regulamentos e leis em diferentes regiões geográficas podem ser um desafio para segurança dos dados das empresas. Atualmente há pouco precedente em matéria de responsabilidade jurídica na nuvem.
- Devido à natureza dinâmica da nuvem, a informação não pode ser imediatamente localizada no caso de um desastre. Planos de Continuidade de Negócio e Recuperação de Desastres devem ser bem documentados e testados.

- Além do risco de ocorrer uma interrupção na continuidade dos negócios, outro fator que deve ser considerado são as invasões por hackers aos ambientes da nuvem, denominado por especialistas de *CyberCloud*. Diferentemente dos hackers comuns esses se apresentam como empresas sofisticadas e bem estabelecidas. Por trás de uma lógica empresarial bem definida, esconde-se uma organização criminosa, que investe alto em pesquisas com a finalidade de ganhar dinheiro.
- Segregação de Dados. Segundo o Gartner Group (2009), é preciso descobrir como se dá a segregação dos dados pelo provedor e principalmente se este utiliza criptografia para os dados em trânsito e/ou armazenados. O fornecedor de nuvem precisa também fornecer evidências de que os esquemas de criptografia utilizados foram projetados e testados por especialistas experientes. "Acidentes com criptografia pode fazer o dado inutilizável e mesmo a criptografia normal pode comprometer a disponibilidade" (GARTNER, 2009).
- Recuperação. Mesmo que o cliente não saiba onde os dados estão, e o que vai acontecer com seus dados e serviços em caso de catástrofe, o fornecedor de nuvem deve saber. Portanto é importante questionar o provedor de nuvem se o mesmo tem "a capacidade de fazer uma restauração completa e quanto tempo vai demorar" (GARTNER, 2009).
- Apoio à investigação. Segundo GARTNER (2009), auditar atividades inadequadas ou ilegais pode ser impossível em Computação em Nuvem. A dificuldade é devida as constantes mutações dos conjuntos de hosts e centros de dados. Se não for possível conseguir um compromisso contratual de apoio a formas específicas de investigação, os pedidos de investigação e descoberta serão impossíveis de se realizar.

4.1. Modelo para gestão de risco na nuvem

Um modelo de gestão de riscos para utilização de serviços da Nuvem para funções críticas do negócio deve incluir:

- Identificação e a avaliação dos ativos;
- Análise de ameaças e vulnerabilidades e mensuração do impacto potencial nos ativos (risco e cenários de incidente);
- Análise das probabilidades de ocorrência de determinados eventos em um cenário de implantação da nuvem;
- Determinação dos níveis de gestão de risco aprovados, seus critérios de aceitação;
- Desenvolvimento de Planos de Tratamentos de Riscos, com múltiplas opções (controle, evitar, transferir, aceitar). Os resultados do plano de tratamento de riscos devem ser parte integrante dos acordos de serviço (SLA).

A abordagem de avaliação de riscos entre o fornecedor e o cliente da Nuvem deve ser consistente, com foco nos critérios de análise de impacto e definição de probabilidade. O cliente e o fornecedor devem desenvolver conjuntamente os cenários de risco para os serviços a serem contratados na Nuvem.

Os serviços, e não apenas o fornecedor, deve ser objeto de avaliação de risco. O uso de serviços em nuvem, e os modelos de implantação a ser utilizado, devem ser coerentes com os objetivos de Gestão de Risco da organização, bem como com seus objetivos de negócio.

5. GESTÃO DE RISCO

A Tabela 2 resume os modelos dos serviços oferecidos pela nuvem e seus riscos relativos. A classificação de risco pode ser modificada para atender as metodologias de avaliação de risco na organização, por exemplo, a norma ABNT NBR ISO/IEC 27005, que trata do processo de Gestão de Riscos de Segurança da Informação. Cada modelo de serviço em nuvem pode ser avaliado como um serviço de ativos da informação, com classificação de risco único e seleção de controles

resultante da mitigação de risco (termos de contrato, conteúdo do SLA, compliance e ferramentas de monitoramento).

A avaliação do risco relativo aumenta de acordo com a movimentação da nuvem. Se há uma movimentação de consumidores de IaaS para PaaS e, finalmente, para SaaS, os modelos de serviço de construção de um sobre o outro, resulta em risco cumulativo, como o provedor da nuvem assume o controle mais direto, há, portanto, maior risco de segurança para o consumidor da nuvem.

- **Tabela 2 – Riscos inerentes dos modelos de serviços na nuvem.**

Modelo de Serviço	Características do Risco	Risco Relativo
Infrastructure as a Service (IaaS)	Neste modelo de serviço o consumidor não administra ou controla a infraestrutura da nuvem subjacente, mas tem controle sobre os sistemas operacionais, armazenamento de aplicativos implantados, e os componentes de rede selecionados.	Médio
Platform as a Service (PaaS)	Neste modelo de serviço o consumidor não administra ou controla os recursos de infraestrutura da nuvem subjacente, tais como componente de rede, servidores, sistemas operacionais, ou armazenamento. Porém o consumidor tem controle sobre os aplicativos utilizados na hospedagem de aplicativos e nas configurações de ambientes.	Alto

Software as a Service (SaaS)	Neste modelo de serviço o consumidor não administra ou controla a infraestrutura subjacente da nuvem. O que inclui componentes de rede, servidores, sistemas operacionais, armazenamento ou capacidade de aplicação individual. A possível exceção relaciona-se a algumas configurações específicas do usuário e de algumas configuração de aplicativos.	Muito Alto

5.1. Requisitos para a gestão de risco na nuvem

As empresas, dependendo do seu ramo de negócio, possuem necessidades distintas e estão sob padrões e regulamentações específicas da natureza de seus negócios. Dessa forma apresentam abordagens diversas para tratar questões relacionadas à gestão de riscos de segurança da informação.

A norma ABNT NBR ISO/ IEC 27005 (2008) estabelece que dentre os principais papéis e responsabilidades da organização para gestão de riscos de segurança da informação está a identificação e análise das partes interessadas e o estabelecimento das relações necessárias entre a organização e as partes interessadas, das interfaces com as funções de alto nível de gestão de riscos da organização (por exemplo: a gestão de riscos operacionais), assim como as interfaces com outros projetos ou atividades relevantes.

Dessa forma, um conjunto principal de requisitos deve ser definido pela organização para guiar os mais diversos esforços em se adotar, adequadamente, uma metodologia de análise e gestão de riscos de segurança da informação, voltada para a contratação dos serviços da Nuvem.

Na busca por um modelo de gerenciamento de riscos de segurança da informação em ambientes de Computação em Nuvem, este trabalho propõe os seguintes requisitos:

- A organização necessita de uma estrutura organizacional de segurança da informação, que deve ser tratada em todos os níveis gerenciais;
- A adoção pela organização das melhores práticas relacionadas à segurança da informação, como a ABNT NBR ISO/IEC 27002;
- A organização precisa definir/adotar uma metodologia de análise e gestão de risco de segurança da informação, que seja cuidadosamente monitorada, principalmente referente ao processo de compliance e gestão de desempenho e que possa ser modificada conforme necessário para reduzir o risco geral de segurança de informação ao longo do tempo;
- A metodologia de análise de risco deve ser modificável, devendo ser analisada durante o processo de controle de gestão para garantir uma gestão de participação e revisão consciente do risco e a aceitação de ambas as opções de tratamento do risco e consequentemente o risco residual;
- As organizações precisam desenvolver e adotar políticas e procedimentos baseados na análise de risco para garantir a segurança das informações na nuvem;
- Organizações precisam estabelecer uma estrutura de gerenciamento de riscos da segurança da informação para definir, explicitamente, o que se espera de cada indivíduo (papéis e responsabilidades);
- É preciso criar e executar um plano para remediar vulnerabilidades ou deficiências que comprometam os dados armazenados na Nuvem;
- As organizações precisam desenvolver e colocar em prática procedimentos de respostas a incidentes relacionados com os serviços da Nuvem;
- Criação de um Plano de Continuidade e Contingência de Negócio, que possa ser testado regularmente, objetivando a disponibilidade dos dados e serviços da Nuvem em caso de interrupção.

6. COMPLIANCE E A NECESSIDADE DE SUA ADOÇÃO

De acordo com Wagner Giovanini, reconhecido Compliance Officer no mundo corporativo, principalmente pelo trabalho realizado na Siemens a partir do final do ano de 2007, após investigações internas sobre notícias de supostos escândalos que estavam ocorrendo ao redor do mundo, cita que no mundo corporativo:

"Compliance está ligado a estar em conformidade com as leis e regulamentos internos e externos à organização. E, cada vez mais, o Compliance vai além do simples atendimento à legislação, busca consonância com os princípios da empresa, alcançando a ética, a moral, a honestidade e a transparência, não só na condução dos negócios, mas em todas as atitudes das pessoas."

No entanto, é válido ressaltar que a palavra Compliance, como dito no início, não existe na língua portuguesa, o que leva a diferentes interpretações. Por exemplo, em outra posição, podendo falar até mesmo em complementação, Luís Roberto Antonik em seu livro "Compliance, Ética, Responsabilidade Social e Empresarial", nos diz que:

"Compliance é um conjunto normativo que assegura o cumprimento de regras de determinado setor. O significado tem como objetivo identificar possibilidades de infrações, falta de cumprimento de uma norma legal ou atividades que se configurem como atos de corrupção."

Atualmente a posição que o Compliance ocupa na sociedade brasileira se encontra intimamente conectada à Operação Lava Jato, que desde 2014 vem expondo uma rede de corrupção presente nos mais diversos setores da sociedade, tendo como foco principal para suas descobertas, a atuação das maiores empresas de engenharia e construção no país.

É imprescindível ressaltar que agregar elementos de um programa anticorrupção demonstra que a empresa está disposta a lutar contra aquele mal, que esse comprometimento com a luta contra a corrupção mostra um impacto positivo na

organização e com o público exterior. Além disso, essas políticas são capazes de fazer com que as pessoas se sintam mais à vontade a demonstrar interesse em atuar pelo bem, contribuindo com denúncias e outras.

Os desdobramentos da aludida operação foram e estão sendo inimagináveis para área pública, descredibilizando a maioria dos políticos do país. No entanto, a área privada sofreu perdas substanciais, como redução do faturamento, cortes de pessoal de até 60%, além do pagamento de multas bilionárias e adequação de suas práticas. É esse o ponto que o Compliance entra em ação e deixa de ser opção, passando a ser obrigação para a continuidade da operação dessas empresas.

As empresas que integravam os esquemas de corrupção estiveram de conluio em diversas obras, tanto em âmbito nacional, quanto em âmbito internacional e, dessa forma, ao admitirem tais práticas, tiveram de adequar sua governança ao assinarem Acordos de Leniência.

Vale destacar duas das empresas que foram pontos focais na Operação Lava Jato: Construtora Norberto Odebrecht e Andrade Gutierrez Engenharia. Ambas assinaram Acordos de Leniência aqui no Brasil, no entanto, a Odebrecht teve ainda maiores complicações, tendo de resolver sua situação com o governo americano da mesma forma.

Os Acordos de Leniência são essencialmente sigilosos, porém, os seus termos não. Dessa forma, pode-se pontuar o que cada um dos acordos prevê para tais empresas, no que diz respeito a instituição de programas de Compliance.

7. COMPLIANCE NA PREVENÇÃO

O compliance nas empresas teve origem nas instituições financeiras, com a criação do Banco Central Americano, em 1913, que objetivou a formação de um sistema financeiro mais flexível, seguro e estável, e, logo após a quebra da Bolsa de

Nova York de 1929, foi criada a Política Intervencionista *New Deal*, em uma tentativa de intervir na economia para “corrigir as distorções naturais do capitalismo” (MANZI, 2008: 27).

Apesar de sua origem e seu avançado desenvolvimento, o conceito e programas de compliance não são exclusivos das instituições bancárias, uma vez que compreende a busca pela aderência entre a ética individual e coletiva, termo anglo-saxão originário do verbo *to comply*, que significa agir de acordo com uma regra, um pedido ou um comando. Segundo a FEBRABAN (2010), compliance é o dever de cumprir, estar em conformidade e fazer cumprir regulamentos internos e externos impostos às atividades da instituição (MORAIS, 2005).

Discutir compliance é compreender a natureza e a dinâmica da corrupção e fraude nas organizações, independentemente de seu ramo de atividade. Entretanto, para as organizações que possuem suas atividades controladas por órgãos reguladores do Poder Público, por se tratarem de atividades de prestação de serviço ao público, como, por exemplo, instituições financeiras, distribuidoras de energia, comunicação, aviação, entre outras, há uma série de exigências legais que devem cumprir, sob pena de até mesmo serem impedidas de exercerem suas atividades, sofrerem danos à sua imagem, ou ainda, sanções às organizações e aos indivíduos (podendo gerar processos administrativos ou até mesmo criminais).

Há ainda aquelas empresas que estão sob a égide de leis como a americana *Sarbanes-Oxley* de 2002, denominada SOX, a qual, em seu artigo 404, aponta que as empresas de capital aberto são obrigadas a adequar os comportamentos éticos dos profissionais e candidatos, bem como buscar a identificação, mitigação, análise das consequências e prevenção de atitudes inadequadas.

A conduta de acordo com a regra (compliance), ou corrupta, possuiu várias causas e é influenciada pelas circunstâncias. Na raiz da conduta corrupta está a percepção moral, a compreensão do indivíduo sobre o significado de sua atitude frente à moral e as regras organizacionais.

No cerne das iniciativas de compliance está a preocupação da quebra da confiança no relacionamento econômico e social das organizações, funcionários e stakeholders.

Exemplificando, o Banco Central do Brasil controla parte das atividades de instituições financeiras autorizando seu funcionamento, estabelecendo regras prudenciais mínimas, supervisionando e fiscalizando suas atividades, assistindo financeiramente, criando regimes especiais de intervenção e liquidação e exigindo seguro de depósitos até determinado montante, com o objetivo de criar uma rede de proteção bancária que, por sua vez, por meio de seus instrumentos, busca conferir mais segurança e confiança a poupadores e investidores (MANZI, 2008).

Por outro lado, a ausência de segurança e de confiança propicia um enfraquecimento das relações econômicas e sociais, segundo Arruda, Whitaker e Ramos (2001:23) “a ausência de valores morais grita a situação atual é o pior dos males que pode afligir o tecido social”.

A importância na prevenção de riscos operacionais é tamanha que o novo Acordo da Basileia, conhecido como Basileia II, a elenca como uma das principais ferramentas para determinar o valor de alocação de capital, o que significa dizer que, por meio de medições quantitativas, é possível definir o grau de falhas nos controles internos que podem afetar a confiança dos investidores naquela instituição financeira (MANZI, 2008).

Analogicamente, pode-se expandir essa preocupação com a prevenção de riscos operacionais como um dos fatores que afetam o desempenho de qualquer organização, quer seja ela uma de capital aberto quer não, pois, sem a mitigação desses riscos, a perenidade da organização pode ser afetada principalmente quanto a um risco à sua reputação, pois esse risco pode gerar impactos ainda maiores do que os regulatórios, pois estes, diferentemente daqueles, são, de certa forma, controlados.

De forma geral, os riscos operacionais são tratados com a utilização da tecnologia de informação como uma ferramenta para eficácia das atividades; implantação de padrões que fomentam as melhores práticas na prestação de serviço do negócio; monitoramento constante dos riscos aos quais a empresa esteja vulnerável; e a prevenção de eventos relacionados à não conformidade por meio de reforço da cultura ética (MANZI, 2008).

Há estudos que analisam o custo-benefício de uma implantação de programas de compliance em organizações, os quais chegaram à conclusão de que para cada U$1,00 gastos são economizados U$5,00 com a mitigação de processos legais, danos à reputação e perda de produtividade (SCHILDER, 2006). Compliance cada vez mais é um fator diferencial para a competitividade das organizações, pois o mercado busca e valoriza a transparência, ética nas suas interações econômicas e sociais. Para Manzi (2008), é possível criar uma vantagem competitiva quando a organização agrega valor para a governança corporativa por meio de ferramentas de compliance que procuram se adequar às melhores práticas do mercado. Entretanto, resta a dúvida de qual a importância dessa adequação.

Segundo Daft (2002), há um movimento de semelhança entre organizações do mesmo setor, e esse fenômeno, chamado por ele de “isomorfismo institucional”, tende a levar as organizações a buscar padrões mais comuns para suas atividades. Isso ocorre primeiramente para minimizar incertezas quanto ao produto que deve ser lançado, por exemplo.

Muitas vezes é utilizada a técnica do benchmarking que tenta entender como as organizações que melhor desempenham determinado produto chegaram a esse padrão. Outro motivo para que ocorra esse isomorfismo é pela pressão de órgãos reguladores governamentais que exigem determinadas condutas e atendimento de diversas regras e normas. Ainda há a pressão por um alto padrão de eficiência e qualidade que permita a continuidade de competir no mercado.

Entretanto, e, não obstante a tudo que aqui foi explanado, a organização necessariamente precisa buscar o compliance como meio de fortalecer sua posição no mercado, e a sociedade precisa encarar a ética não só como uma forma de ação conveniente, mas também como uma condição de sobrevivência da sociedade. Um risco do mensurar a adoção de compliance é a não correlação do custo-benefício de sua implantação com o retorno esperado, mesmo porque riscos reputacionais encontram dificuldade de mensuração e, mesmo que assim não o fosse, compliance não é uma questão financeira, mas uma questão de princípios (SCHILDER, 2006).

O Brasil atualmente está em um patamar que coloca compliance como um dos pilares da governança corporativa ao garantir a conformidade com normas, leis e políticas internas e externas à organização, bem como ao fortalecer o ambiente ético por meio de controles internos e aumento da transparência.

“Certamente não se pode falar em governança corporativa e sustentabilidade sem se referir à ética e consequentemente considerar a importância de compliance.” (MANZI, 2008: 123).

Para Manzi (2008), são elementos fundamentais de um programa de compliance: desenvolver código de ética da organização; desenvolver os profissionais na capacidade de lidar com dilemas éticos; criar canais de identificação de condutas não éticas e possibilitar a discussão de dilemas éticos.

Todo gestor deve ser um disseminador da cultura compliance na organização, indo mais além, todo funcionário assim deve agir. Entretanto, é recomendável que exista na organização um gestor de compliance, o qual terá a função de estruturar o desenvolvimento de compliance para toda organização. Essa função ou área, dependendo da demanda da organização, será responsável por verificar se as atividades e produtos da organização estão em conformidade com as leis; prever, mitigar e tratar riscos de não aderência às normas internas; difundir o conhecimento de compliance para toda a organização; fortalecer a cultura de controles internos; e

reportar os assuntos ligados a compliance e ética para a alta gestão da organização (MANZI, 2008).

Apesar de existir grande intersecção entre as áreas de compliance e auditoria interna, pois a primeira deve acompanhar os pontos de vulnerabilidade que esta apontou como a que necessita de regularização, há algumas diferenças em suas atividades.

A auditoria interna verifica processos das áreas internas da organização com o intuito de identificar seu nível de conformidade com as normas e políticas, mas assim o faz de forma aleatória por amostragem.

Já compliance deve assim proceder de forma rotineira e permanente, buscando a prevenção dos riscos aos quais a organização pode estar ou ser exposta, bem como tratar os casos de não conformidade. Assim como a Auditoria Interna, compliance também deve ser independente, reportando à alta administração; entretanto, ele pode e deve ser auditado pela auditoria interna como as demais áreas, o que reforça a transparência de suas atividades, gerando um maior conforto para seus profissionais e para as demais áreas, servindo inclusive como exemplo (MANZI, 2008).

8. CONTROLES PARA A IMPLANTAÇÃO DA LGPD

Os controles aqui discutidos são uma parcela do conjunto definido pela metodologia BEST, restringindo-se apenas àqueles diretamente conectados à Lei Geral de Proteção de Dados Pessoais (LGPD). Para compatibilidade com a metodologia BEST, foram mantidos os identificadores de controle da metodologia completa.

O mapeamento dos artigos da LGPD identificou a aplicação de controles relativos aos seguintes programas:

- PG00 - Programa de Gestão de Cibersegurança e Segurança da Informação;
- PG06 - Programa de Informações Protegidas;
- PG03 - Programa de Continuidade de Negócios;
- PG08- Programa de Atitudes Seguras.

A ordem lógica de implantação impõe o início pelos controles relativos ao PG00 - Programa de Gestão de Cibersegurança e Segurança da Informação. Esses controles, a rigor, não se referem diretamente à LGPD. Entretanto, a implantação do PG00 é necessária para que haja consistência e acompanhamento dos princípios da LGPD, além de ser uma forma de atender aos requisitos determinados em seu art. 50.

A seguir, recomenda-se a implantação do programa PG06 - Programa de Informações Protegidas, que inclui a maior parte das exigências relativas à LGPD. Os programas PG03 e PG08, a serem implantados parcialmente, completam o conjunto identificado diretamente com a LGPD. Graficamente, pode-se ilustrar este processo como na sugestão mostrada na figura. Tal processo pode ser paralelizado.

Figura: sugestão de ordem de implantação

Fonte: Lei Geral de Proteção de Dados Pessoais (LGPD) – Guia de implantação. Editora Blucher.

8.1. PG00 - Programa De Gestão De Cibersegurança E Segurança Da Informação

Entende-se que a implantação efetiva dos requisitos previstos na LGPD exige a instalação de um Sistema de Gestão apropriado às finalidades da LGPD e ao estágio organizacional e econômico de cada Organização, configurando assim o Sistema de Gestão de Cibersegurança e Segurança da Informação (SGCSI).

O art. 50 determina que os Controladores e Operadores poderão formular regras de boas práticas e governança, individualmente ou em grupo. A implantação do SGCSI é uma fonte para atender aos requisitos expressos nesse artigo.

De acordo com o artigo, a implantação de um programa de governança de proteção de dados exige que (art. 50):

- demonstre o comprometimento do controlador em adotar processos e políticas internas que assegurem o cumprimento, de forma abrangente, de normas e boas práticas relativas à proteção de dados pessoais;
- seja aplicável a todo o conjunto de dados pessoais que estejam sob seu controle, independentemente do modo como se realizou sua coleta;
- seja adaptado à estrutura, à escala e ao volume de suas operações, bem como à sensibilidade dos dados tratados;
- estabeleça políticas e salvaguardas adequadas com base em processo de avaliação sistemática de impactos e riscos à privacidade;
- tenha o objetivo de estabelecer relação de confiança com o titular, por meio de atuação transparente e que assegure mecanismos de participação do titular;
- esteja integrado a sua estrutura geral de governança e estabeleça e aplique mecanismos de supervisão internos e externos;
- conte com planos de resposta a incidentes e remediação; e
- seja atualizado constantemente com base em informações obtidas a partir de monitoramento contínuo e avaliações periódicas.

Esses requisitos são atendidos integralmente pela implantação do PG00 - Programa Gestão de Cibersegurança e Segurança da Informação, focado nessas demandas e que está dividido em quatro grupos de controles, a saber:

- GC0.1. Estruturação do SGCSI;
- GC0.2. Implantação do SGCSI;
- GC0.3. Manutenção do SGCSI;
- GC0.4. Execução do SGCSI.

Note que os controles relativos a estruturação, implantação, manutenção e ex cução do SGCSI estão separados apenas com o intuito de explicitar do process Entende-se necessário realizar uma estruturação inicial antes que se possa realizar sua implantação. Por sua vez, a implantação deve ser faseada no tempo, respeitand os direcionadores de negócio da Organização; por exemplo, pode ser mais prioritári atender à implantação da LGPD do que à revisão da segurança de rede. A manutençã do SGCSI é uma demanda natural porque a Organização se altera: novas estrutura organizacionais, novos negócios, novas práticas precisam ser incorporados. Mas, par os processos ou áreas em que o SGCSI já está implantado, há de ser executado con forme determinado.

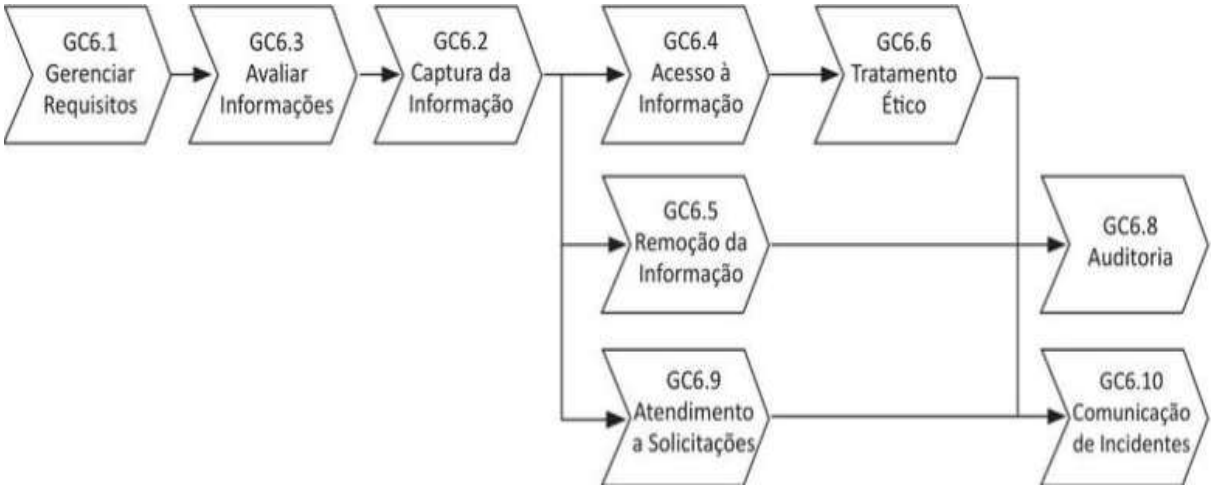
8.2. PG06 - Programa De Informações Protegidas

O Programa de Informações Protegidas (PG06) é o que trata da proteção às Informações Sensíveis no âmbito do processamento e do armazenamento. Engloba os seguintes grupos de controles:

- GC6.1. Gerenciar requisitos para Informações Protegidas: trata do estabelecimento do modelo de classificação de informações, da caracterização dos tratamentos e da arquitetura técnica, bem como do estabelecimento dos papéis de Controlador, Operador e Encarregado no contexto LGPD.
- GC6.2. Captura da Informação: aborda os aspectos de captação de dados com a respectiva autorização do Titular.

- GC6.3. Avaliação da Informação: trata da aplicação do modelo de classificação.
- GC6.4. Acesso à Informação: trata dos controles e do registro de acesso às Informações Sensíveis.
- GC6.5. Remoção da Informação: trata da exclusão de informações nas condições determinadas pela LGPD.
- GC6.6. Tratamento Ético: determina quando o processamento pode ser consi derado ético e, portanto, legítimo, além de abordar as hipóteses de tratamento previstas na LGPD.
- GC6.7. Acesso às mídias de armazenamento: trata do acesso físico às Informações Sensíveis.
- GC6.8. Auditoria de Segurança e Privacidade: trata das atividades de auditoridade determinadas pela LGPD.
- GC6.9. Atendimento a Solicitações: trata do atendimento de solicitações pelo diversos atores definidos na LGPD.
- GC6.10. Comunicação de Incidentes: trata dos requisitos de comunicação à Autoridade Nacional de Proteção de Dados (ANPD).

Figura: sugestão de sequencia de implantação do PG06



Fonte: Lei Geral de Proteção de Dados Pessoais (LGPD) – Guia de implantação. Editora Blucher.

8.3. PG03 - Programa De Continuidade De Negócios

A metodologia BEST endereça vários outros aspectos da questão de Continuidade de Negócios que não foram aqui discutidos porque não têm referência direta na LGPD.

8.3.1. GC3.1. BACKUP

Realizar backup de dados automaticamente.

Lei Geral de Proteção de Dados - LGPD	
Artigo 6º, inciso VII - As atividades de tratamento de dados pessoais deverão observar a boa-fé e os seguintes princípios: [...] **VII - segurança: utilização de medidas técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou difusão [...]**	**Artigo 46 - Art. 46. Os agentes de tratamento devem adotar medidas de segurança, técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou qualquer forma de tratamento inadequado ou ilícito.** **§ 1º A autoridade nacional poderá dispor sobre padrões técnicos mínimos para tornar aplicável o disposto no caput deste artigo, considerados a natureza das informações tratadas, as características específicas do tratamento e o estado atual da tecnologia, especialmente no caso de dados pessoais sensíveis, assim como os princípios previstos no caput do art. 6º desta Lei.** **§ 2º As medidas de que trata o caput deste artigo deverão ser observadas desde a fase de concepção do produto ou do serviço até a sua execução.**

8.4. PG08 - Programa De Atitudes Seguras

A metodologia BEST endereça vários outros aspectos na questão de Atitudes Seguras que não foram aqui discutidos porque não têm referência direta na LGPD.

8.4.1. GC8.2. Treinamento

Realizar treinamento em Segurança da Informação.

Lei Geral de Proteção de Dados - LGPD	
Artigo 41, parágrafo 2º, inciso III - O controlador deverá indicar encarregado pelo tratamento de dados pessoais. [...] **§ 2º As atividades do encarregado consistem em: [...]** **III - orientar os funcionários e os contratados da entidade a respeito das práticas a serem tomadas em relação à proteção de dados pessoais. [...]**	**Artigo 50 - Art. 50. Os controladores e operadores, no âmbito de suas competências, pelo tratamento de dados pessoais, individualmente ou por meio de associações, poderão formular regras de boas práticas e de governança que estabeleçam as condições de organização, o regime de funcionamento, os procedimentos, incluindo reclamações e petições de titulares, as normas de segurança, os padrões técnicos, as obrigações específicas para os diversos envolvidos no tratamento, as ações educativas, os mecanismos internos de supervisão e de mitigação de riscos e outros aspectos relacionados ao tratamento de dados pessoais.** **§ 1º Ao estabelecer regras de boas práticas, o controlador e o operador levarão em consideração, em relação ao tratamento e aos dados, a natureza, o escopo, a finalidade e a probabilidade e a gravidade dos riscos e dos benefícios decorrentes de tratamento de dados do titular.** **§ 2º Na aplicação dos princípios indicados nos incisos VII e VIII do caput do art. 6º desta Lei, o controlador, observados a estrutura, a escala e o volume de suas operações, bem como a sensibilidade dos dados tratados e a probabilidade e a gravidade dos danos para os titulares dos dados, poderá:** **I - implementar programa de governança em privacidade que, no mínimo:** **a) demonstre o comprometimento do controlador em adotar processos e políticas internas que assegurem o cumprimento, de forma abrangente, de normas e boas práticas relativas à proteção de dados pessoais;** **b) seja aplicável a todo o conjunto de dados pessoais que estejam sob seu controle,**

	independentemente do modo como se realizou sua coleta; **c) seja adaptado à estrutura, à escala e ao volume de suas operações, bem como à sensibilidade dos dados tratados;** **d) estabeleça políticas e salvaguardas adequadas com base em processo de avaliação sistemática de impactos e riscos à privacidade;** **e) tenha o objetivo de estabelecer relação de confiança com o titular, por meio de atuação transparente e que assegure mecanismos de participação do titular;** **f) esteja integrado a sua estrutura geral de governança e estabeleça e aplique mecanismos de supervisão internos e externos;** **g) conte com planos de resposta a incidentes e remediação; e** **h) seja atualizado constantemente com base em informações obtidas a partir de monitoramento contínuo e avaliações periódicas;** **II - demonstrar a efetividade de seu programa de governança em privacidade quando apropriado e, em especial, a pedido da autoridade nacional ou de outra entidade responsável por promover o cumprimento de boas práticas ou códigos de conduta, os quais, de forma independente, promovam o cumprimento desta Lei.** **§ 3º As regras de boas práticas e de governança deverão ser publicadas e atualizadas periodicamente e poderão ser reconhecidas e divulgadas pela autoridade nacional.**

REFERÊNCIAS

ARMBRUST, M, Fox, A., Griffith, R., Anthony D. Joseph, Randy Katz, Andy Konwinski, Gunho Lee, David Patterson, Ariel Rabkin, Ion Stoica, and Matei Zaharia **- "Above the Clouds: A Berkeley View of Cloud Computing**" – UC Berkeley Reliable Adaptive Distributed Systems Laboratory - February 10, 2009 http://radlab.cs.berkeley.edu/.

BERNARDES, M. C., MOREIRA, E. S., - **Um Modelo da Governança da Segurança da Informação no Escopo da Governança Organizacional.** Instituto de Ciências Matemáticas e de Computação – ICMC, Universidade de São Paulo. São Paulo – Brasil.

CSA (Cloud Security Alliance) **- Security Guidance for Critical Areas of Focus in Cloud Computing V2.1** Prepared by the Cloud Security Alliance December 2009 ABNT – Associação Brasileira de Normas Técnicas. Tecnologia da Informação – Código de Prática para a Gestão da Segurança da Informação.

DIKAIAKOS M.D., PALLIS G., KATSAROS D., MEHRA P., VAKALI A., - **Cloud Computing:** Distributed Internet Computing for IT and Scientific Research, Published by the IEEE Computer Society - p. 10-13 - Nicosia, Greece - September/October 2009 –- www.computer.org/internet/.

GARCIA, Lara Rocha. Et al**. Lei Geral de Proteção de Dados Pessoais (LGPD) – Guia de implantação.** Editora Blucher. 1º edição. 2020.

Government Considerations for the Cloud Computing Environment, August 2009 – USA. Disponível em http://boozallen.com/publications.

ISACA, Emerging Technology **– "Cloud Computing: Business Benefits with Security**, Governance and Assurance Perspectives." – ISACA, Illions, USA – Oct, 2009. Disponível em http://www.isaca.org.

KANDUKURI, Balachandra Reddy; V, **Ramakrishna Paturi; RAKSHIT, Dr. Atanu. Cloud Security Issues.** IEEE International Conference on Services Computing, Pune, India, n. p.517-520, September 2009.

KAUFMAN, Lori M. et al. **Data Security in the World of Cloud Computing:** It all Depends. Published by the IEEE Computer and Reliability Societies, Virginia, USA, n. p.61-64, ago. 2009. http://www.computer.org/security

KORZENIOWSKI, Paul. **Segurança na Nuvem**: Padrões estão sendo trabalhados. Information Week, EUA - 20/11/2009.

KUROSE, J. F.; ROSS, K.W., **Redes de Computadores e a Internet** – Uma Abordagem Top-Down. 3ª Ed., Pearson Addison Wesley, São Paulo, SP - 2005.

MILLER, J., Candle, L., Wald, H., - **Information Security Governance:**

MLADEN A. Vouk, **Cloud Computing:** Issues, Research and Implementations Journal of Computing and Information Technology - CIT 16, 2008, 4, p. 235–246 Department of Computer Science, North Carolina State University, Raleigh, North Carolina, USA.

NBR ISO/IEC 27002: 30/09/2005. **ABNT – Associação Brasileira de Normas Técnicas.** Tecnologia da Informação – Técnicas de Segurança – Gestão de Riscos de Segurança da Informação. NBR ISO/IEC 27005: 07/08/2008.

NEXTGENERATION (Brasil). Intel (Org**.). Dialogo TI - Cloud Computing**.

NIST (National Institute of Standards and Technology) - **The NIST Definition of Cloud Computing, Version 15,** 10-7-2009, National Institute of Standards and Technology, Information Technology Laboratory – Gaithersburg, Maryland – USA. Disponível em: http://www.nist.org.

TAURION, Cezar. **Cloud Computing:** Transformando o Mundo do TI. 1ª Ed., Editora Brasport, Rio de Janeiro, RJ - 2009.